

الوحدة 11: هجمات لاسلكية وكلمات المرور

Wireless Attacks (هجمات لاسلكية)

Evil Twin: نقطة وصول وهمية (Access Point) تحاكي شبكة Wi-Fi شرعية. يتصل بها المستخدم ظناً أنها الشبكة الأصلية، مما يسمح للمهاجم باعتراض البيانات.

(Deauthentication Attack (Deauth: إرسال حزم Deauth لإجبار الأجهزة على قطع اتصالها بشبكة Wi-Fi، ثم إعادة الاتصال بنقطة الوصول الوهمية (Evil Twin).

WEP Cracking: WEP (Wired Equivalent Privacy) بروتوكول تشفير قديم وضعيف. يمكن كسره بسهولة باستخدام أدوات مثل aircrack-ng بسبب ثغراته في RC4.

الوقاية: استخدام WPA3، تجنب الشبكات المفتوحة، استخدام VPN، تعطيل SSID broadcast (ليس كافياً وحده).

مثال: استخدام aircrack-ng لاختبار أمان WEP

```
aircrack-ng -b 00:11:22:33:44:55 capture.cap
```

الشرح جزءاً جزءاً:

aircrack-ng أداة تحليل واختبار أمان Wi-Fi.

-b 00:11:22:33:44:55 يحدد BSSID (عنوان MAC) لنقطة الوصول المستهدفة.

capture.cap ملف يحتوي على حزم ملتقطة من الشبكة.

تستخدم الأداة هذه الحزم لاستخراج مفتاح WEP. استخدم فقط على شبكاتك الخاصة أو المصرح بها.

Password Attacks (هجمات كلمات المرور)

Brute Force: تجربة جميع التركيبات الممكنة لكلمة المرور حتى إيجاد الصحيحة. بطيء لكنه فعال ضد كلمات المرور الضعيفة.

Dictionary Attack: استخدام قائمة كلمات شائعة (Wordlist) بدلاً من جميع التركيبات. أسرع من Brute Force.

Rainbow Tables: جداول تحتوي على تجزئات (Hashes) محسوبة مسبقاً لكلمات مرور شائعة. تقارن التجزئة المسروقة بالتجزئات في الجدول لاستنتاج كلمة المرور. **الوقاية:** استخدام Salting (إضافة بيانات عشوائية قبل التجزئة).

مثال: استخدام Hydra لهجوم Brute Force على SSH

```
hydra -l root -P passwords.txt ssh://192.168.1.100
```

الشرح جزءاً جزءاً:

hydra أداة اختراق كلمات مرور متعددة البروتوكولات.

root- 1 يحدد اسم المستخدم (root).

passwords.txt P يحدد ملف كلمات المرور (Wordlist).

ssh://192.168.1.100 الهدف عبر بروتوكول SSH.

تنبيه: استخدم فقط بترخيص كتابي.

Pass-the-Hash و Replay Attack

Replay Attack: اعتراض بيانات صالحة وإعادة إرسالها لخداع النظام. مثال: اعتراض طلب تسجيل دخول وإعادة إرساله.

الوقاية: استخدام Timestamps و Nonces في البروتوكولات.

Pass-the-Hash: يستخدم تجزئة كلمة المرور (Hash) بدلاً من كلمة المرور نفسها للمصادقة. شائع في هجمات Windows باستخدام NTLM hashes.

الوقاية: استخدام Kerberos بدلاً من NTLM، تفعيل Credential Guard.

مثال: استخدام nmap لفحص شبكة لاسلكية

```
nmap -sP 192.168.1.0/24
```

الشرح: مسح ping للشبكة المحلية لاكتشاف الأجهزة المتصلة. مفيد لتحديد الأجهزة النشطة على الشبكة قبل تنفيذ هجمات أخرى (في سياق اختبار الاختراق المصرح به فقط).

(Quick Quiz (MCQ

1. Which attack creates a fake wireless access point to impersonate a legitimate network ?

- a) Deauthentication
- b) Evil Twin
- c) WEP Cracking
- d) Brute Force

Answer: b

2. (Which wireless security standard uses SAE (Simultaneous Authentication of Equals ?

- a) WEP
- b) WPA
- c) WPA2
- d) WPA3

Answer: d

3. Which attack uses precomputed hash tables to reverse password hashes ?

- a) Brute Force

- b) Dictionary attack
- c) Rainbow Tables
- d) Replay attack

Answer: c

?Which tool is used to brute force login credentials for SSH .4

- a) nmap
- b) hydra
- c) aircrack-ng
- d) tcpdump

Answer: b

?What is the primary defense against Rainbow Table attacks .5

- a) AES encryption
- b) Salting
- c) JWT tokens
- d) SSL certificates

Answer: b